

Top 10 web hacking techniques of 2021 - nominations open



James Kettle
Director of Research
[@albinowax](#)



Published: Wednesday, 5 January 2022 at 14:35 UTC

Updated: Monday, 31 January 2022 at 15:02 UTC



Update: nominations are now closed, but voting is live! [Cast your vote here](#).

Nominations are now open for the top 10 new web hacking techniques of 2021!

Every year security researchers share their discoveries via blog posts, presentations, and whitepapers. Every write-up is valuable, but some contain something special - innovative ideas and techniques that can be re-applied elsewhere. Since 2006, the security community has annually joined forces to sift through the year's findings and uncover the top ten pieces of research, selected for their innovation and lasting impact. At PortSwigger Research we're proud to be hosting this once again.

If this is your first time encountering this project, you can find the full origin, history and purpose of this project on our [dedicated top 10 page](#), along with an archive of past winners and explanation of how it differs from related projects like the OWASP Top Ten.

Timeline

Today: Start collecting community nominations for the top research from 2021.

Jan 17: Launch community vote to build a shortlist of the top 15.

Jan 24: Launch panel vote on shortlist to select and order the 10 finalists.

Feb 08: Publish top 10 of 2021!.

What should I nominate?

The aim is to highlight research containing novel, practical techniques that can be re-applied to different systems. Individual vulnerabilities like log4shell are valuable at the time but typically age poorly, whereas underlying techniques such as JNDI Injection can be reapplied to great effect. Nominations can also be refinements to already-known attack classes, such as [Exploiting XXE with Local DTD Files](#). For further examples, you might find it useful to check out [previous year's top 10s](#).

Making a nomination

To submit, simply provide a URL to the research, and an optional brief comment explaining what's novel about the work. Feel free to make as many nominations as you like, and nominate your own research if you think it's worthy! I'll filter out weaker nominations and merge overlapping ones to keep the total number manageable.

[Click here to make a nomination](#)

We don't collect email addresses - to get notified when the voting stage starts, follow [@PortSwiggerRes](#) on Twitter.

Nominations:

- [JSON Interoperability Vulnerabilities](#)
- [Dependency Confusion](#)
- [Universal Deserialisation Gadget for Ruby 2.x-3.x](#)
- [The Secret Parameter, LFR, and Potential RCE in NodeJS Apps](#)
- [Misconfigurations in Java XML Parsers](#)
- [Hidden OAuth attack vectors](#)
- [Breaking GitHub Private Pages for \\$35k](#)
- [Forgot password? Taking over user accounts Kaminsky style](#)
- [HTTP/2: The Sequel is Always Worse](#)
- [HTTP Smuggling via Higher HTTP Versions](#)
- [Integer overflow vulnerability in HAProxy](#)
- [Prototype Pollution](#)
- [Practical HTTP Header Smuggling](#)
- [T-Regs: HTTP Request Smuggling with Differential Fuzzing](#)
- [uBlock, I exfiltrate: exploiting ad blockers with CSS](#)
- [Empirical Study of HTTP Request Smuggling in Servers and Proxies](#)
- [Weird proxies/2 and a bit of magic](#)
- [Response Smuggling- Pwning HTTP-1.1 Connections](#)
- [RCE in Homebrew by compromising the official Cask repository](#)
- [Bypassing 2FA using OpenID Misconfiguration](#)
- [Pop-Ups in a good-world](#)
- [XSS to RCE in the Opera Browser](#)
- [Attacking the DevTools](#)
- [AppCache's forgotten tales](#)
- [Web Cache Deception Escalates!](#)
- [Local File Read via Stored XSS in The Opera Browser](#)

- [LEXSS: Bypassing Lexical Parsing Security Controls](#)
- [Fuzzing for XSS via nested parsers condition](#)
- [Ping'ing XMLSec](#)
- [A Scientific Notation Bug in MySQL exposed AWS WAF](#)
- [Securing XML implementations across the web](#)
- [Cache Poisoning at Scale](#)
- [HotPics 2021](#)
- [Remote code execution in cdnjs of Cloudflare](#)
- [A New Attack Surface on MS Exchange - ProxyLogon](#)
- [Exploiting CSP in Webkit to Break Authentication & Authorization](#)
- [You Talking To Me?](#)
- [Play the Opera Please](#)
- [Hacking CloudKit - How I accidentally deleted your Apple Shortcuts](#)
- [Turning Blind Error Based MSSQL Injection into Exploitable Boolean One](#)

top-10-techniques

Top 10 Hacking Techniques

← [Back to all articles](#)

Related Research



Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering

 **PortSwigger**

 [Follow us](#)

© 2026 PortSwigger Ltd.

